

DevSecOps Tools – Complete Guide Sheet (Ready to Share)

This guide covers **what the tool is**, **how it's used in real DevSecOps pipelines**, **free learning resources**, **hands-on project ideas**, and **scenario-based interview questions**.

1 CI/CD TOOLS (Jenkins, GitHub Actions, GitLab CI)

♦ What They Are (DevSecOps Angle)

CI/CD tools automate **build** → **test** → **scan** → **deploy** pipelines.

In DevSecOps, they act as the **security automation backbone**, enforcing:

- Static code analysis (SAST)
 - Dependency scanning
 - Container scanning
 - Policy gates (fail builds on vulnerabilities)
-

♦ Jenkins

Type: Open-source automation server

Why used: Highly customizable, plugin ecosystem, self-hosted control

DevSecOps Use Cases

- Run SAST tools (SonarQube) during build
- Integrate Trivy scans before Docker image push
- Enforce security gates before production deploy

Free Learning Resources

- Jenkins Official Docs (Free)
- YouTube: *TechWorld with Nana*, *Abhishek Veeramalla*
- Jenkins Hands-on Labs (Katacoda alternatives)

Project Ideas

1. Secure CI Pipeline with Jenkins + SonarQube + Trivy
2. Jenkins Pipeline with Docker Image Scan & Policy Fail
3. Jenkins + Kubernetes + Security Gates before deployment

Scenario-Based Interview Questions

- How do you stop a Jenkins pipeline if critical vulnerabilities are found?
 - How would you secure Jenkins credentials in a DevSecOps setup?
 - Jenkins vs GitHub Actions for security pipelines — when would you choose Jenkins?
-

◆ GitHub Actions

Type: Cloud-native CI/CD

Why used: Tight GitHub integration, YAML-based, zero infra management

DevSecOps Use Cases

- Pull request security scans
- Automated dependency scanning
- Secure image builds using GitHub-hosted runners

Free Learning Resources

- GitHub Actions Documentation
- GitHub Skills (Free interactive labs)
- YouTube: *freeCodeCamp*, *DevOps Toolkit*

Project Ideas

1. PR-based Security Pipeline with Trivy & SonarQube
2. GitHub Actions → Docker Build → Scan → Push Securely
3. Secure Release Workflow with Manual Approval Gates

Scenario-Based Interview Questions

- How do you implement security scanning on pull requests?
 - How do you store secrets securely in GitHub Actions?
 - How would you prevent vulnerable code from being merged?
-

◆ GitLab CI

Type: Integrated DevOps platform

Why used: Built-in DevSecOps features

DevSecOps Use Cases

- Native SAST, DAST, dependency scanning
- Security dashboards
- Auto security reports

Free Learning Resources

- GitLab CI Docs
- GitLab Learn (Free)
- YouTube: *TechWorld with Nana*

Project Ideas

1. GitLab Secure Pipeline using Built-in SAST + DAST
2. Container Scan + Deploy Only If Secure
3. GitLab CI with Kubernetes Security Policies

Scenario-Based Interview Questions

- How does GitLab CI differ from Jenkins in DevSecOps?
 - How do GitLab security stages work?
 - How would you implement DAST in GitLab CI?
-

TRIVY

♦ What It Is

Type: Vulnerability scanner

Scans:

- Docker images
- File systems
- Kubernetes clusters
- IaC (Terraform, Kubernetes YAML)

Why It Matters

- Finds CVEs early
- Prevents insecure images from reaching production

Free Learning Resources

- Trivy GitHub Repo (Docs)
- Aqua Security Blogs
- YouTube: *DevOps Toolkit*

Project Ideas

1. Docker Image Scan Pipeline using Trivy
2. Kubernetes Cluster Vulnerability Scanner
3. IaC Security Scanner for Terraform & K8s YAML

Scenario-Based Interview Questions

- How do you fail a pipeline if critical CVEs are found?
 - Trivy vs Clair — what's the difference?
 - How do you scan Kubernetes clusters with Trivy?
-

3 FALCO

♦ What It Is

Type: Runtime security tool

Monitors system calls to detect suspicious activity in real time.

Why It Matters

- Detects container escape attempts
- Detects crypto mining, shell access, privilege escalation

Free Learning Resources

- Falco Official Docs
- Sysdig Blog
- YouTube: *CNCF, DevOps Toolkit*

Project Ideas

1. Runtime Threat Detection in Kubernetes using Falco
2. Falco Alerts → Slack Integration
3. Detect Unauthorized Shell Access in Containers

Scenario-Based Interview Questions

- How does Falco work internally?
 - How is runtime security different from image scanning?
 - What actions would you take when Falco raises an alert?
-

4 SONARQUBE

♦ What It Is

Type: Static Code Analysis (SAST)

Detects:

- Bugs
- Code smells
- Security vulnerabilities

Why It Matters

- Shifts security left
- Improves code quality & security

Free Learning Resources

- SonarQube Community Edition
- SonarSource Docs
- YouTube: *TechWorld with Nana*

Project Ideas

1. CI Pipeline with SonarQube Quality Gates
2. Multi-language Secure Code Analysis
3. Secure Microservices Codebase with SonarQube

Scenario-Based Interview Questions

- What are quality gates and why are they important?
 - How do you integrate SonarQube with CI/CD?
 - SAST vs DAST — where does SonarQube fit?
-

5 OWASP ZAP

♦ What It Is

Type: Dynamic Application Security Testing (DAST) tool
Simulates real-world attacks on running applications.

Why It Matters

- Finds runtime vulnerabilities
- Catches misconfigurations & auth flaws

Free Learning Resources

- OWASP ZAP Docs
- OWASP WebGoat
- YouTube: *OWASP Foundation*

Project Ideas

1. DAST Pipeline with OWASP ZAP
2. Automated Security Testing for Web App
3. ZAP Scan Reports Integrated into CI/CD

Scenario-Based Interview Questions

- How does DAST differ from SAST?
- When should ZAP be used in a pipeline?
- How do you automate ZAP scans safely?

BONUS: End-to-End DevSecOps Mini Architecture

Code → CI/CD → SonarQube → Trivy → Deploy → ZAP → Runtime → Falco

-